SIMATS ENGINEERING
ASSESSMENT TOOL 3

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Scenario-Based Assessment

Topic 1: Footprinting Tools – Conducting Competitive Intelligence

Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

Task: Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

Topic 2: DNS Zone Transfers

Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Scenario Based Assessment

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

ANSWERS

Name: M Prabhas **Reg No:** 1924722064

Answer 1 (15 Marks)

Approach: Since the assessment must remain fully passive (no direct interaction with ABC Technologies' servers), only OSINT/footprinting tools that query public, third-party data sources are used. Each piece of required information is mapped to the most suitable tool below.

1. Domain Registration Details

Tool: WHOIS (whois command / whois.domaintools.com)

WHOIS queries the domain registrar's public database to reveal the registrant organization, registration and expiry dates, name servers, and registrar contact information. For competitive intelligence, this shows how long the company has owned the domain, which registrar/hosting ecosystem it relies on, and sometimes administrative or technical contact details that hint at the IT team or outsourced vendor.

2. Employee Email Addresses

Tool: theHarvester

theHarvester aggregates data from search engines, PGP key servers, and other public sources to compile employee email addresses tied to the domain. This reveals the organization's email naming convention and the roles/departments represented (Support, Sales, HR, Admin, Technical), which is valuable for understanding organizational structure and potential contact points.

3. Technology Stack

Tool: BuiltWith / Wappalyzer

These tools passively analyze a website's front-end and back-end signatures (CMS, web server, frameworks, analytics tools, CDN, payment processors) to fingerprint the technology stack. For competitive intelligence this reveals the company's technology choices and vendor relationships, and can hint at potential version-specific weaknesses to be aware of (for later, authorized, active testing).

4. Publicly Exposed Subdomains

Tool: Sublist3r (or crt.sh certificate transparency search)

Sublist3r enumerates subdomains passively by querying search engines, DNS aggregators, and certificate transparency logs (crt.sh). This reveals the breadth of the company's public-facing footprint, such as dev., staging., vpn., or mail. subdomains, which is useful competitive intelligence about the scale and maturity of their online infrastructure.

Summary - Value for Competitive Intelligence

Together, WHOIS, theHarvester, BuiltWith/Wappalyzer, and Sublist3r build a complete passive profile of ABC Technologies: who owns and manages the domain, who the key personnel/departments are, what technologies they have invested in, and how large their external attack surface is - all without sending a single packet directly to the company's own servers, keeping the assessment strictly passive and legally safe.

Answer 2 (15 Marks)

Tool/Command Used: dig axfr @<nameserver> <domain> (the dig command with the axfr query type, directed at the organization's authoritative name server, is the standard way to request a full DNS zone transfer).

Example: dig axfr @ns1.targetcompany.com targetcompany.com

Verifying Whether Zone Transfer Is Permitted

- First identify the authoritative name servers for the domain using: dig NS targetcompany.com
- Then attempt the zone transfer against each listed name server with: dig axfr @<nameserver> targetcompany.com
- If the server is properly secured, it returns a 'Transfer failed' or 'connection refused' message. If misconfigured, it returns the entire zone file in cleartext, confirming the vulnerability.

How the Retrieved Records Could Be Used in Reconnaissance

- A/AAAA records: directly reveal the IP addresses of internal and external hosts, allowing the attacker to build a target list for scanning without further guessing.
- MX records: identify the organization's mail servers, which can be targeted for mail-relay abuse or used to craft convincing spoofed/phishing emails.
- NS records: reveal secondary/internal name servers that may not be intended for public exposure.
- CNAME/subdomain records: expose internal naming conventions and additional subdomains (e.g., intranet, vpn, dev, backup) that were never meant to be discoverable, effectively giving the attacker a map of the internal network without active scanning.
- Combined, this single successful zone transfer can replace days of manual subdomain brute-forcing and port scanning, dramatically accelerating the reconnaissance phase of an attack.

Recommendation

If the transfer succeeds, this should be reported as a critical finding. The organization should restrict AXFR to authorized secondary DNS servers only (via ACLs/TSIG), disable zone transfers to arbitrary hosts, and separate internal and external DNS views.

Answer 3 (20 Marks)

Type of Social Engineering Attack: This is a Phishing attack, more specifically a Credential Harvesting / Spoofed-Sender Phishing attack carried out through pretexting (the attacker impersonates the trusted IT department and invents an urgent pretext - a 'security update' - to pressure employees into acting without verification).

Why It Is Phishing

- It arrives via email and impersonates a trusted internal source (the IT department).
- It creates a false sense of urgency ('urgent security update') to short-circuit careful judgment.
- It directs the victim to click a link and enter their login credentials - the hallmark objective of a credential-harvesting phishing page.

Countermeasures Employees Should Apply Before Responding

- Verify the sender's actual email address/domain rather than trusting the display name, and look for subtle misspellings or an external domain.
- Hover over (without clicking) the embedded link to inspect the real destination URL before trusting it.
- Never enter credentials through a link in an unsolicited email; instead, navigate to the organization's known, bookmarked login portal directly.
- Contact the IT department through an independent, known channel (phone extension, internal chat) to verify whether the 'urgent update' request is genuine.

- Report the email immediately using the organization's phishing-report mechanism instead of replying or interacting with it.
- Avoid enabling macros, downloading attachments, or entering any information until the email's legitimacy has been confirmed.

How These Actions Help Prevent Credential Theft

Verifying the sender and the actual link destination exposes the spoofing before any data is entered, stopping the attack at the reconnaissance/delivery stage. Using only known, bookmarked portals and independently confirming requests with IT removes the attacker's ability to exploit urgency and trust. Prompt reporting also allows the security team to block the sender, take down the phishing page, and warn other employees, limiting the campaign's overall impact and preventing mass credential compromise.